

SEGURIDAD CON THYMELEAF Y SPRING



spring



spring
BOOT

Seguridad en Plantillas Thymeleaf con Spring Security

Objetivo

Ocultar dinámicamente los botones de acción (Agregar, Editar y Eliminar) en la vista, según el rol del usuario, usando etiquetas de seguridad de **Thymeleaf**.

◆ Paso 1: Agregar la dependencia de Thymeleaf Extras para Seguridad

Ubicación:

pom.xml

Agrega la siguiente dependencia:

```
<dependency>
  <groupId>org.thymeleaf.extras</groupId>
  <artifactId>thymeleaf-extras-springsecurity6</artifactId>
</dependency>
```

✅ Esta librería permite usar nuevas etiquetas de seguridad (`sec:`) en las páginas HTML.

Después, actualiza el proyecto:

- Clic derecho en el proyecto → Clean and Build.
- O usa Maven > Reload Project.

◆ Paso 2: Configurar el Namespace de Seguridad en la Plantilla Principal

Ubicación:

```
src/main/resources/templates/layout/layout.html
```

Agrega el siguiente namespace en la etiqueta `<html>`:

```
xmlns:sec="http://www.thymeleaf.org/extras/spring-security"
```

✅ Esto activa las etiquetas de seguridad de Thymeleaf dentro de la plantilla.

◆ Paso 3: Mostrar el Usuario y Roles Activos en el Footer

En el archivo:

```
src/main/resources/templates/layout/layout.html
```

Dentro del `footer`, agrega:

```
<b>User:</b> <span sec:authentication="name">Nombre de usuario</span>
<b>Roles:</b> <span sec:authentication="principal.authorities">Roles</span>
```

✅ Así se mostrará automáticamente el nombre del usuario y los roles asignados en la parte inferior.

◆ Paso 4: Ocultar el link "Crear Persona" si el Usuario no es Admin

Ubicación:

src/main/resources/templates/index.html

Agrega el atributo `sec:authorize` al link **Crear Persona**:

```
<a sec:authorize="hasRole('ROLE_ADMIN')" th:href="@{/agregar}">[[#{persona.crear}]]</a>
```

✓ Solo usuarios con rol `ADMIN` podrán ver este link.

◆ Paso 5: Ocultar las Columnas de Editar y Eliminar si el Usuario no es Admin

En la tabla de personas en `index.html`, agrega en los encabezados:

```
<th sec:authorize="hasRole('ROLE_ADMIN')">[[#{accion.editar}]]</th>
<th sec:authorize="hasRole('ROLE_ADMIN')">[[#{accion.eliminar}]]</th>
```

Y también en cada fila de la tabla:

```
<td sec:authorize="hasRole('ROLE_ADMIN')">
  <a th:href="@{/editar/{id}(id=${persona.idPersona})}">[[#{accion.editar}]]</a>
</td>
<td sec:authorize="hasRole('ROLE_ADMIN')">
  <a th:href="@{/eliminar(idPersona=${persona.idPersona})}">[[#{accion.eliminar}]]</a>
</td>
```

✓ Así, usuarios que no sean `ADMIN` no podrán ver ni los links de editar ni de eliminar.

◆ Paso 6: Ejecutar y Probar

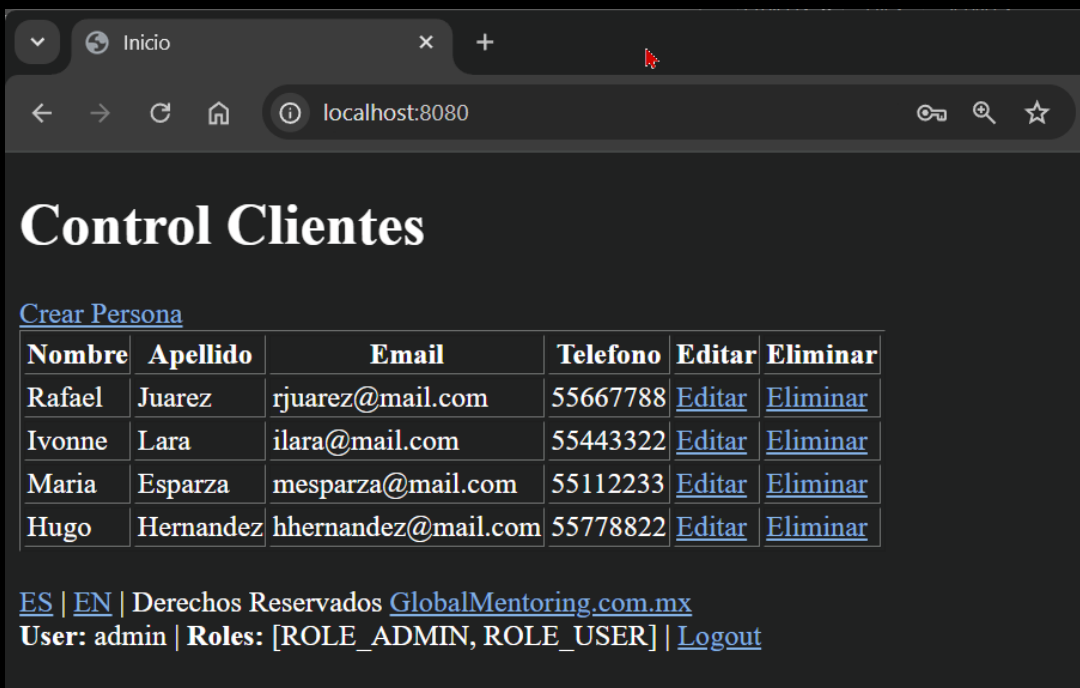
1. Ejecuta tu proyecto (Run).
2. Abre <http://localhost:8080>.
3. Inicia sesión con:

- Usuario: `admin`
- Password: `123`

0

- Usuario: `user`
 - Password: `123`
4. Verás que puedes realizar todas las acciones con el usuario **admin**, pero se habrán ocultado las acciones de Crear Persona, Editar o Eliminar para el usuario **user**.
 5. Haz clic en **Logout** para cerrar sesión para cambiar de usuarios y probar sus roles asignados.

✦ Usuario con permisos de ADMIN:

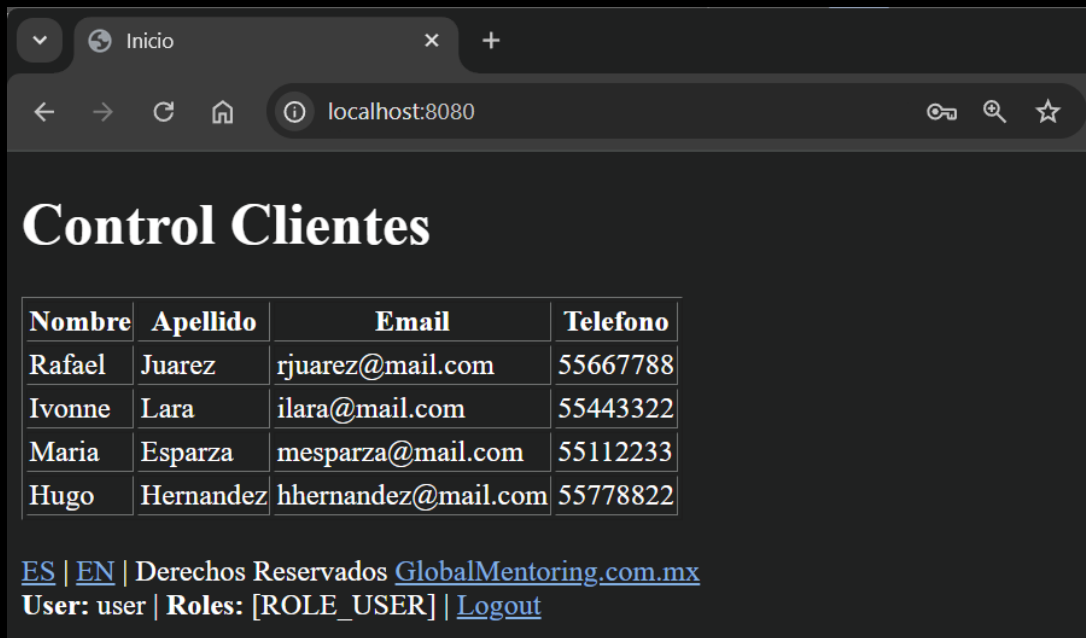


The screenshot shows a web browser window with the address bar set to `localhost:8080`. The page title is "Control Clientes". Below the title, there is a link "Crear Persona". A table displays client information with columns for Name, Surname, Email, Phone, Edit, and Delete. The table contains five rows of data. At the bottom, there is a footer with links for "ES", "EN", and "GlobalMentoring.com.mx", along with user information: "User: admin | Roles: [ROLE_ADMIN, ROLE_USER] | Logout".

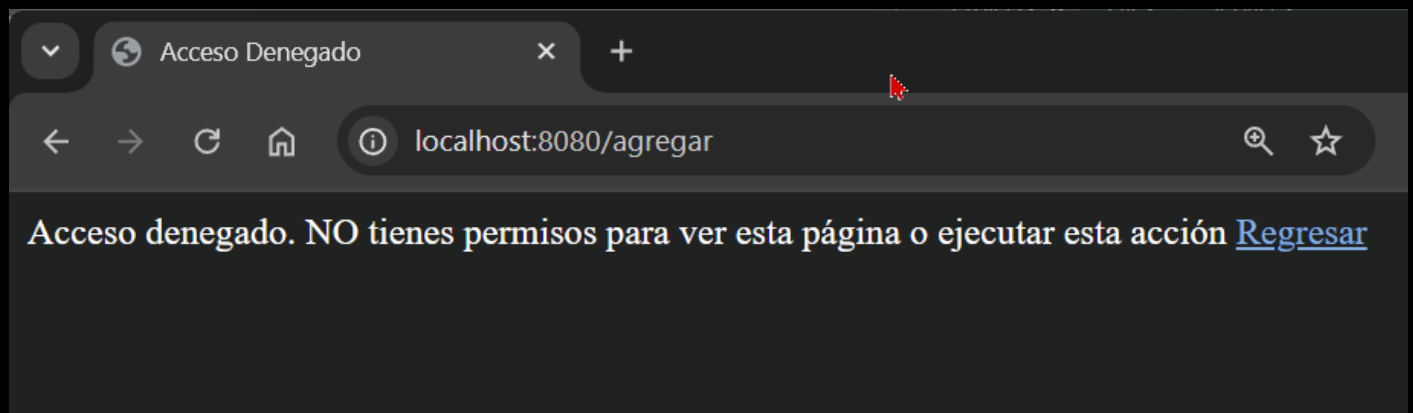
Nombre	Apellido	Email	Telefono	Editar	Eliminar
Rafael	Juarez	rjuarez@mail.com	55667788	Editar	Eliminar
Ivonne	Lara	ilara@mail.com	55443322	Editar	Eliminar
Maria	Esparza	mesparza@mail.com	55112233	Editar	Eliminar
Hugo	Hernandez	hhernandez@mail.com	55778822	Editar	Eliminar

[ES](#) | [EN](#) | Derechos Reservados [GlobalMentoring.com.mx](#)
User: admin | Roles: [ROLE_ADMIN, ROLE_USER] | [Logout](#)

✦ Usuario con permisos de USER:



6. Si intentas acceder directamente a una ruta no permitida se muestra la siguiente página:



✨ Código Final Consolidado

✂ Código de pom.xml:

```
<?xml version="1.0" encoding="UTF-8"?>
<project xmlns="http://maven.apache.org/POM/4.0.0" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://maven.apache.org/POM/4.0.0 https://maven.apache.org/xsd/maven-
4.0.0.xsd">
  <modelVersion>4.0.0</modelVersion>
```

```
<parent>
  <groupId>org.springframework.boot</groupId>
  <artifactId>spring-boot-starter-parent</artifactId>
  <version>3.4.4</version>
  <relativePath/> <!-- lookup parent from repository -->
</parent>
<groupId>gm</groupId>
<artifactId>ControlClientes</artifactId>
<version>0.0.1-SNAPSHOT</version>
<name>ControlClientes</name>
<description>Control de Clientes con Spring</description>
<url/>
<licenses>
  <license/>
</licenses>
<developers>
  <developer/>
</developers>
<scm>
  <connection/>
  <developerConnection/>
  <tag/>
  <url/>
</scm>
<properties>
  <java.version>21</java.version>
</properties>
<dependencies>
  <dependency>
    <groupId>org.springframework.boot</groupId>
    <artifactId>spring-boot-starter-thymeleaf</artifactId>
  </dependency>
  <dependency>
    <groupId>org.springframework.boot</groupId>
    <artifactId>spring-boot-starter-web</artifactId>
  </dependency>

  <dependency>
    <groupId>org.springframework.boot</groupId>
    <artifactId>spring-boot-devtools</artifactId>
    <scope>runtime</scope>
    <optional>true</optional>
  </dependency>
  <dependency>
    <groupId>org.springframework.boot</groupId>
```

```

        <artifactId>spring-boot-starter-test</artifactId>
        <scope>test</scope>
    </dependency>
    <dependency>
        <groupId>com.mysql</groupId>
        <artifactId>mysql-connector-j</artifactId>
        <scope>runtime</scope>
    </dependency>
    <dependency>
        <groupId>org.springframework.boot</groupId>
        <artifactId>spring-boot-starter-data-jpa</artifactId>
    </dependency>
    <dependency>
        <groupId>org.springframework.boot</groupId>
        <artifactId>spring-boot-starter-validation</artifactId>
    </dependency>
    <dependency>
        <groupId>org.springframework.boot</groupId>
        <artifactId>spring-boot-starter-security</artifactId>
    </dependency>
    <dependency>
        <groupId>org.thymeleaf.extras</groupId>
        <artifactId>thymeleaf-extras-springsecurity6</artifactId>
    </dependency>
</dependencies>

<build>
    <plugins>
        <plugin>
            <groupId>org.springframework.boot</groupId>
            <artifactId>spring-boot-maven-plugin</artifactId>
        </plugin>
    </plugins>
</build>

</project>

```

✦ Código de plantilla.html:

```

<!DOCTYPE html>
<html xmlns="http://www.w3.org/1999/xhtml"
      xmlns:th="http://www.thymeleaf.org"
      xmlns:sec="http://www.thymeleaf.org/extras/spring-security">

```

```

<head>
    <title>Plantilla</title>
    <meta charset="UTF-8"/>
</head>
<body>
    <header th:fragment="header">
        <h1 th:text="#{plantilla.titulo}">Titulo</h1>
    </header>

    <footer th:fragment="footer">
        <div>
            <br/>
            <a th:href="@{/ (lang=es) }">ES</a> |
            <a th:href="@{/ (lang=en) }">EN</a> |
            <span>
                [[#{plantilla.pie-pagina}]]
                <a href="http://www.globalmentoring.com.mx"
                    target="_blank">GlobalMentoring.com.mx</a>
            </span>
            <form method="POST" th:action="@{/logout}">
                <b>User:</b> <span sec:authentication="name">Usuario que hizo login</span> |
                <b>Roles:</b> <span sec:authentication="principal.authorities">Roles</span> |
                <a href="#" onclick="this.parentNode.submit();">Logout</a>
            </form>
        </div>
    </footer>

</body>
</html>

```

✚ Código de index.html:

```

<!DOCTYPE html>
<html xmlns:th="http://www.thymeleaf.org"
    xmlns:sec="http://www.thymeleaf.org/extras/spring-security">
    <head>
        <title>Inicio</title>
        <meta charset="UTF-8">
    </head>
    <body>

        <header th:replace="~{layout/plantilla :: header}"></header>

```



```

<a sec:authorize="hasRole('ROLE_ADMIN')" th:href="@{/agregar}">[[#{persona.crear}]]</a>

<div th:if="${personas != null and !personas.empty}">
    <table border="1">
        <tr>
            <th>[[#{persona.nombre}]]</th>
            <th>[[#{persona.apellido}]]</th>
            <th>[[#{persona.email}]]</th>
            <th>[[#{persona.telefono}]]</th>
            <th sec:authorize="hasRole('ROLE_ADMIN')">[[#{accion.editar}]]</th>
            <th sec:authorize="hasRole('ROLE_ADMIN')">[[#{accion.eliminar}]]</th>
        </tr>
        <tr th:each="persona : ${personas}">
            <td th:text="${persona.nombre}">Nombre</td>
            <td th:text="${persona.apellido}">Apellido</td>
            <td th:text="${persona.email}">Email</td>
            <td th:text="${persona.telefono}">Telefono</td>
            <td sec:authorize="hasRole('ROLE_ADMIN')">
                <a th:href="@{/editar/{id}(id=${persona.idPersona})}">[[#{accion.editar}]]</a>
            </td>
            <td sec:authorize="hasRole('ROLE_ADMIN')">
                <a
                    th:href="@{/eliminar(idPersona=${persona.idPersona})}">[[#{accion.eliminar}]]</a>
                </td>
        </tr>
    </table>
</div>

<div th:if="${personas == null or personas.empty}">
    [[#{persona.lista-vacia}]]
</div>

<footer th:replace="~{layout/plantilla :: footer}"></footer>

</body>
</html>

```



¡Listo!

Ahora:

- El botón "Crear Persona" solo lo ven los administradores.

- Las opciones de "Editar" y "Eliminar" desaparecen para usuarios normales.
- Se muestra el nombre de usuario y sus roles al pie de página.
- Tu aplicación se ve **más segura y profesional**. 🙌

Sigue adelante con tu aprendizaje 🚀, ¡el esfuerzo vale la pena!

¡Saludos! 🙌

Ing. Marcela Gamiño e Ing. Ubaldo Acosta

Fundadores de [GlobalMentoring.com.mx](https://www.globalmentoring.com.mx)